



Ауторизација над ресурсом и класификација података

Провера приступа конкретном ресурсу и правила руковања подацима

Ауторизација над конкретним ресурсом

Одлука о приступу обухвата субјекат, тражену радњу, конкретан ресурс и контекст у коме захтев настаје.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Ауторизација има смисла тек када је везана за конкретан ресурс и његов контекст.

Корисник може имати легитимну улогу, а ипак не сме да чита, мења или дели баш тај запис. Зато се одлука не завршава провером типа ендпоинта или назива улоге.

ЗНАЧАЈ

Значај за безбедност система

Класификација података даје исти језик власницима, развоју и операцијама. Када систем зна колико је податак осетљив, може да примени одговарајући приступ, приказ, чување и евиденцију без ослањања на нечије сећање.

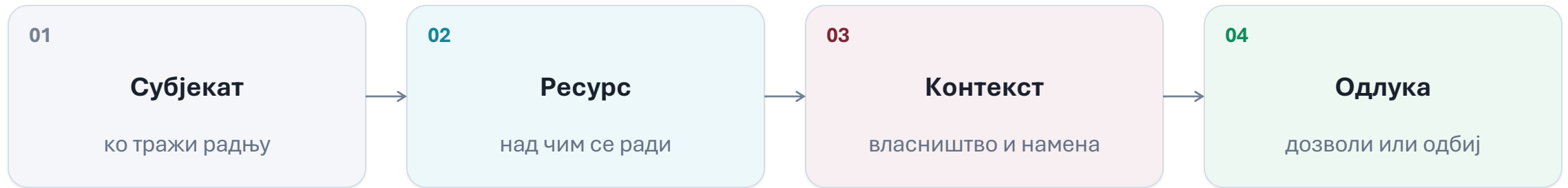
КРИТЕРИЈУМ ПРОВЕРЕ

Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

ОСНОВНИ ПОЈМОВИ

Субјекат, ресурс, контекст и одлука чине основу провере приступа конкретном запису.



ЗАКЉУЧАК

Идентификатор у адреси не представља право приступа. Однос субјекта према ресурсу проверава се на серверу.

Субјекат

ко тражи радњу

01

Субјекат је потврђен идентитет са скупом дозвола; одлука полази од њега, а не од података из захтева.

Питање: који улаз покреће ову одлуку?

02

Дозвола за читање својих записа не укључује туђе; шири приступ је посебна, именована дозвола.

Питање: која граница мора бити видљива?

03

Запис о одлуци чува ко је тражио приступ и на основу које дозволе је исход донет.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Које дозволе субјекат мора да има за свој запис, а које за туђи?

Ресурс

над чим се ради

01

Ресурс има власника и класификацију; оба податка улазе у одлуку пре читања садржаја.

Питање: који улаз покреће ову одлуку?

02

Одбијање не треба да открива садржај нити постојање туђег осетљивог ресурса.

Питање: која граница мора бити видљива?

03

Исти принцип важи за API позив, извоз података и позадинску обраду, не само за екран.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

Контекст

власништво и намена

01

Власништво повезује субјекта и ресурс: исти захтев има различит исход за власника и за другог корисника.

Питање: који улаз покреће ову одлуку?

02

Класификација одређује докле сеже шира дозвола; запис са највишом ознаком остаје доступан само власнику.

Питање: која граница мора бити видљива?

03

Власник податка одговара за промену класификације, а систем чува траг те промене.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Која чињеница о односу субјекта и ресурса мења исход при истој улози?

Одлука

дозволи или одбиј

01

Одлука се доноси на серверу, над конкретним записом, пре него што се садржај прочита.

Питање: који улаз покреће ову одлуку?

02

Сваки исход има стабилан код разлога, па се одбијање може тестирати и објаснити.

Питање: која граница мора бити видљива?

03

Негативан тест за сваки разлог одбијања доказује да граница заиста постоји.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који кодови исхода постоје у вашој одлуци и који тест доказује сваки од њих?

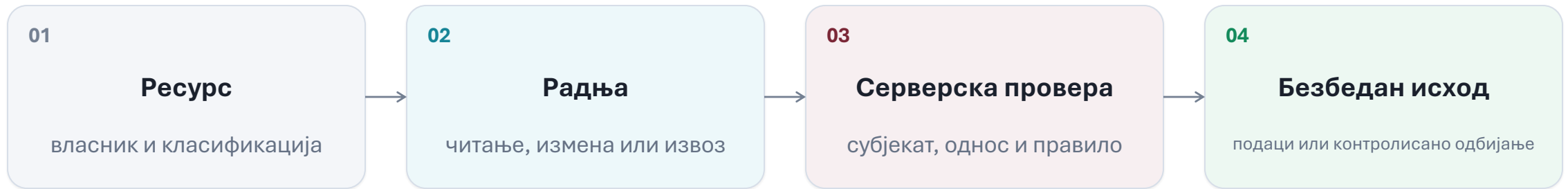
Нивои провере приступа

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Ниво	Шта проверава	Зашто није довољан сам
Пријава	Идентитет субјекта.	Не говори шта субјекат сме да уради.
Улога	Општи скуп одговорности.	Не зна однос према конкретном запису.
Ресурс	Власништво, припадност и класификацију.	Мора се комбиновати са радњом и политиком.
Контекст	Време, стање и пословно оправдање.	Може променити закључак за исту улогу.

Модел заштите једног ресурса

Идентификатор у адреси не представља право приступа. Однос субјекта према ресурсу проверава се на серверу.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Животни циклус податка

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Животни циклус податка

Заштита података не завршава се у тренутку читања. Исти податак пролази кроз креирање, употребу, дељење, чување и уклањање. Свака фаза поставља друго питање о дозвољеном приступу и потребном трагу.

01

При креирању се одређују власник и класификација.

02

При коришћењу се проверава сврха и опсег приступа.

03

При дељењу се проверава граница поверења и минимални скуп података.

04

При чувању и уклањању важе ретентион и audit правила.

Одлука мора имати контекст

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01

Провера права укључује субјект, радњу, ресурс и његову припадност.

Јасно правило

02

Одбијање не треба да открива садржај нити постојање туђег осетљивог ресурса.

Проверљива примена

03

Класификација представља улаз у правила руковања подацима.

Видљив доказ

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

За сваку значајну операцију тим формулише и позитиван и негативан сценарио. Негативан сценарио проверава да правилно пријављен корисник не може да заобиђе власништво променом идентификатора или позивом API-ја ван интерфејса.

01

Дефинисана одлука и њена граница.

02

Серверска имплементација провере.

03

Позитиван и негативан доказ.

Случај: исправна улога, погрешан запис

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: исправна улога, погрешан запис

Два члана тима имају исту улогу и обојица могу да прегледају захтеве. Један мења идентификатор у адреси захтева и долази до туђег записа. Систем који проверава само улогу сматра захтев дозвољеним, иако се променио најважнији део контекста: однос корисника према конкретном ресурсу.

01

Одлука укључује идентитет, тражену радњу, ресурс и припадност ресурса одговарајућем домену или власнику.

02

Исти принцип важи за API позив, извоз података и позадинску обраду, не само за екран који корисник види.

03

Одговор на одбијени приступ треба да буде користан клијенту, али не сме да открије податке о заштићеном запису.

Одлука се доноси над конкретним ресурсом

Метода проверава дозволу, власништво и класификацију пре читања ресурса.

```
1 public ResourceAccessDecision Decide(  
2     Requester requester, ProtectedResource resource)  
3 {  
4     if (!requester.Permissions.Contains(Permissions.ReadRecords))  
5         return new(false, ResourceAccessCodes.MissingReadPermission);  
6     if (resource.OwnerId == requester.ActorId)  
7         return new(true, ResourceAccessCodes.OwnerAccess);  
8     if (!requester.Permissions.Contains(Permissions.ReadAnyRecord))  
9         return new(false, ResourceAccessCodes.NotOwner);  
10    return resource.Classification == DataClassification.Restricted  
11        ? new(false, ResourceAccessCodes.RestrictedToOwner)  
12        : new(true, ResourceAccessCodes.ElevatedAccess);  
13 }
```

ТУМАЧЕЊЕ

Иста улога не значи исти приступ сваком запису. Сервер проверава дозволу, власништво и класификацију.

БЕЗБЕДНОСНА ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Негативан тест доказује границу

Тест мења власника ресурса и очекује одбијање са стабилним кодом разлога.

```
1 [Test]
2 public void Decide_WhenRequesterIsNotOwner_Denies()
3 {
4     var decision = _policy.Decide(
5         Requester("marko", Permissions.ReadRecords),
6         Resource(DataClassification.Internal));
7
8     Assert.That(decision, Is.EqualTo(
9         new ResourceAccessDecision(false, ResourceAccessCodes.NotOwner)));
10 }
```

ДОКАЗ

Тест мења само власника ресурса и очекује одбијање без откривања туђих података.

ОЧЕКИВАНИ ИСХОД

Тест мења једну чињеницу и очекује јасан, стабилан разлог одбијања.

Садржај безбедносног записа

Запис садржи контекст потребан за реконструкцију одлуке, без тајни и непотребних личних података.

```
1 {  
2   "actor": "u-17",  
3   "action": "record.read",  
4   "target": "record-93",  
5   "classification": "internal",  
6   "outcome": "denied",  
7   "reason": "scope_mismatch"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, токен, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01

Провера улоге без провере односа према конкретном ресурсу.

Нема јасног власника одлуке.

02

Филтрирање листе у клијенту без исте провере на серверу.

Не постоји негативан сценарио.

03

Снижавање класификације без образложења и трага промене.

Доказ не показује стварни исход.

Критеријуми потпуне ауторизације

Провера обухвата серверску границу, негативне сценарије и запис разлога одлуке.

ОБРАЗЛОЖЕЊЕ

Како знамо да је ауторизација потпуна

Приступ се проверава на стварној граници система. Директан API захтев, позадински процес и извоз примењују исто правило. Негативни тестови описују границу приступа и очекивани разлог одбијања.

01

Систем једнако штити ресурс када се захтев пошаље ван стандардног екрана.

02

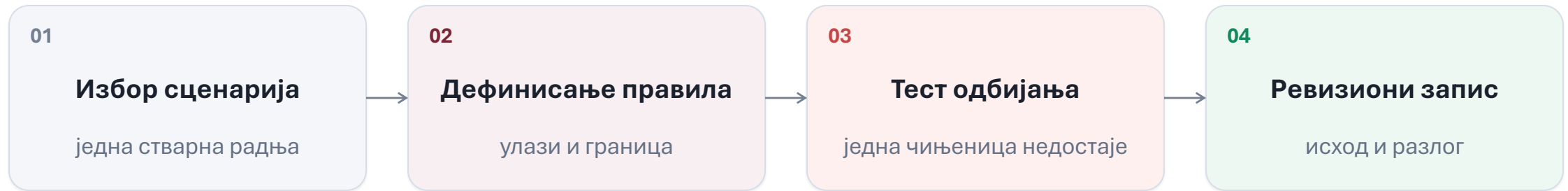
Одбијени захтев не враћа детаље који помажу да се мапирају туђи подаци.

03

Промена класификације и промена власништва остављају довољно трага за каснији преглед.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

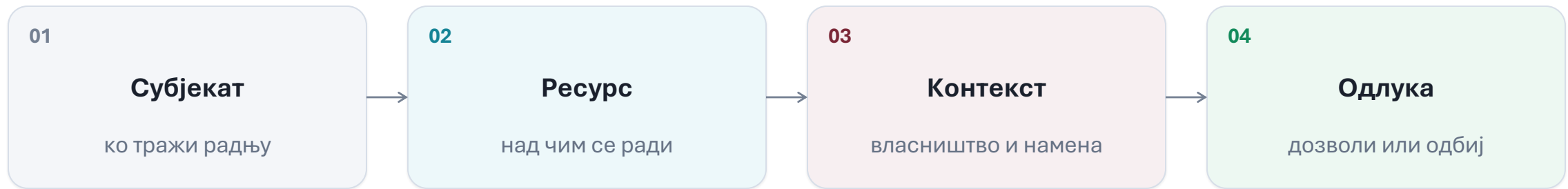


ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „Ауторизација над ресурсом и класификација података“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.



ПИТАЊЕ ЗА ПРОВЕРУ

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.